

CISSP Guide to Security Essentials, Second Edition

Chapter 6 *Legal, Regulations, Investigations, and Compliance*

Objectives

- Computer related crime
- Categories of law and computer crime laws in the U.S. and other countries
- Security incident response
- Investigations
- Computer forensics
- Professional ethics

The Role of Computers in Crime

- Target
 - **Equipment theft.** Computer or network hardware is stolen.
 - **Equipment vandalism.** Computer or other hardware is damaged or defaced.
 - **Data theft.** Data stored on a computer is stolen.
 - **Data vandalism.** Data (which can include software) stored on a computer is changed, damaged, or destroyed.
 - **Trespass.** A party logically enters a computer or other system without authorization.

The Role of Computers in Crime (cont.)

- Instrument
 - Data theft and vandalism
 - Trespass
 - Harassment
 - Spam
 - Fraud
 - Eavesdrop
 - Espionage

The Role of Computers in Crime (cont.)

- Support
 - **Recordkeeping.** A criminal may use a computer to track or support criminal activities.
 - **Conspiracy.** Two or more individuals may conspire to commit a crime, using computers as the means to communicate and plan the crime.
 - **Aid and abet.** A party may aid and abet criminals through the use of a computer, for instance by providing information via e-mail or sending funds via e-mail or an online service.

Categories of Computer Crimes

- Political espionage and cyber-warfare
- Terrorism
- Theft and fraud
- Commercial espionage
- Harassment
- Hacktivism
- Cybervandalism

Political Espionage and Cyber-warfare

- Cyberspace now a theater of war (in addition to land, sea, air, and space)
- Operations to obtain military and political intelligence
- Operations to harm government, military, and civilian targets

Terrorism

- Terrorism: the unlawful use of force or violence against persons or property to intimidate or coerce a government, the civilian population, or any segment thereof, in furtherance of political or social objectives
- Targets: governments, military, public utilities, public health, communications and media, transportation, financial, “icons”

Theft and Fraud

- Direct attacks to illegally obtain funds or information
- Embezzlement
- Extortion and blackmail
- Identity theft

Commercial Espionage

- Competitive intelligence
- Financial gain
- Denial of service

Harassment

- Bullying
- Cyberstalking
- Defamation
- Libel
- Slander

Hacktivism

- Actions against governments and organizations
- Sociopolitical motivation

Cybervandalism

- Defacement
- Compromise with malware
 - Drive-by attacks on future visitors
- Denial of service

Categories of U.S. Laws

- **Criminal law.** This includes laws of public order against crimes such as assault, arson, theft, burglary, deception, obstruction of justice, bribery, and perjury. Law enforcement agencies are responsible for enforcing criminal laws. Criminal laws in the U.S. are published in the United States Code (U.S.C.).
- **Civil law.** This includes contract law, tort law, property law, employment law, and corporate law. Civil law is the branch of laws that generally involve two parties that have a grievance that needs to be settled. Law enforcement agencies generally have little to do with civil laws. Civil laws in the U.S. are published in the United States Code (U.S.C.).
- **Administrative law.** These laws form the framework for the operation of U.S. government agencies such as the Federal Trade Commission, the Department of Agriculture, and the Federal Communications Commission. Administrative law in the United States in the U.S. Code of Federal Regulations, commonly known as the C.F.R.

U.S. Computer Crime Laws

- Intellectual property types
 - Copyrights ©. Exclusive rights for literary works, movies, dances, musical compositions, audio recordings, etc.
 - Patents. Designs of machinery, processes, software.
 - Trademarks[™] and ® service marksSM. Names, slogans, logos for products and services.
 - Trade secrets. Unregistered information.



U.S. Computer Crime Laws (cont.)

- Noteworthy intellectual property laws
 - Economic Espionage Act of 1996
 - Digital Millennium Copyright Act (DMCA) of 1998
 - No Electronic Theft (NET) Act

U.S. Privacy Laws

- Fourth Amendment
- Privacy Act of 1974
- Electronic Communications Act of 1986
- Electronic Communications Privacy Act (ECPA) of 1986
- Computer Matching and Privacy Protection Act of 1988
- Communications Assistance for Law Enforcement Act (CALEA) of 1994

U.S. Privacy Laws (cont.)

- Economic and Protection of Proprietary Information Act of 1996
- Health Insurance Portability and Accountability Act (HIPAA) of 1996
- Children's Online Privacy Protection Act (COPPA) of 1998
- Identity Theft and Assumption Deterrence Act of 1998
- Gramm-Leach-Bliley Act (GLBA) of 1999
- Provide Appropriate Tools Required to Intercept and Obstruct Terrorism (PATRIOT) Act of 2001
- Health Information Technology for Economic and Clinical Health Act (HITECH) of 2009

U.S. Computer Crime Laws

- Access Device Fraud, 1984
- Computer Fraud and Abuse Act of 1984
- Computer Security Act of 1987
- National Information Infrastructure Protection Act of 1996
- Sarbanes-Oxley Act of 2002
- Federal Information Security Management Act of 2002 (FISMA)
- Controlling The Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act of 2003
- Identity Theft and Assumption Deterrence Act of 2003
- U.S. state laws on electronic privacy and breach notification

Canadian Computer Crime Laws

- Interception of Communications (Criminal Code of Canada, § 184)
- Unauthorized User of Computer (Criminal Code of Canada, § 342.1)
- Privacy Act, 1983
- Personal Information Protection and Electronic Documents Act (PIPEDA)

European Computer Crime Laws

- Computer Misuse Act 1990 (CMA)
- The Regulation of Investigatory Powers Act 2000
- Anti-terrorism, Crime and Security Act 2001
- Data Protection Act 1998 (DPA)
- Privacy and Electronic Communications Regulations 2003
- Fraud Act 2006
- Police and Justice Act 2006
- Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data
- Directive on the Protection of Personal Data (95/46/EC)

Laws in Other Countries

- Two categories
 - **Unauthorized entry.** In many countries it is now a crime to access a computer when one is not authorized to do so.
 - **Creation or distribution of malware.** Many countries now make it illegal to create, release, or distribute malware.

Managing Compliance

- Organizations in many countries required to comply with laws and regulations related to data protection
- Organizations frequently adopt a framework of controls to manage compliance (and security):
 - COBIT (Control Objectives for Information and Related Technology)
 - COSO (Committee of Sponsoring Organizations of the Treadway Commission)
 - ISO 27002 (Code of Practice for Information Security Management)

Security Incident Response

- Incident declaration
- Triage
- Investigation
- Analysis
- Containment
- Recovery
- Debriefing

Incident Declaration

- Triggers
 - Malfunctions and outages
 - Threat or vulnerability alerts
 - News media
 - Customer notification
 - Internal staff
- Declaration triggers response operations

Triage, Investigation, Analysis

- Identification and analysis of information
- Search for root cause
- Assignment of experts
- Analysis
 - What happened?
 - How did it happen?
 - What is the scope?
 - How can it be contained?

Containment

- Halt the incident
- Prevent further spread or damage
- Prevent its recurrence
- “Put out the fire”

Recovery

- Restoration to pre-incident condition
 - Repair / replace hardware
 - Reinstall OS or application software
 - Remove unwanted programs and data
 - Restore damaged / missing data
 - Include measures to prevent recurrence

Debriefing

- Reflect on what happened and on its response
- Propose improvements
 - Technical architecture
 - Technical controls
 - Processes and procedures
 - Security incident response

Assumption of Breach

- Old way of thinking: breach prevention, and no news is good news
- New mindset: one or more breaches may have already occurred, whether discovered or not
- Blended investment in breach prevention and breach response

Incident Management Preventive Measures

- Creation of a vulnerability and threat awareness capability
 - Security alerts from U.S. Cert, Secunia, SANS, etc.
 - Organization internal events such as terminations
 - Events detected by firewalls, intrusion prevention systems, data leakage prevention systems, netflow
- Implementation of a defense in depth strategy to protect assets

Incident Response Training, Testing, and Maintenance

- Four types of tests
 - Procedure review
 - Formal training
 - Incident walkthrough
 - Incident simulation

Incident Response Models

- CERT Coordination Center (CERT/CC). Formed in 1988 after the Morris Worm Incident. www.cert.org/csirts/.
- Forum of Incident Response and Security Teams (FIRST). www.first.org.
- National Institute of Standards and Technology (NIST) special publication 800-61, Computer Security Incident Handling Guide. www.nist.gov.

Types of Investigations

- Employee misconduct
- Malware
- Stolen asset
- Violation of acceptable use policy

Involving Law Enforcement

- Many companies reluctant
- Pros
 - Punishment for the guilty
 - Restitution
- Cons
 - Negative publicity
 - Details of the business a part of the public record

Forensic Techniques and Procedures

- Primary activities
 - Identify and gather evidence
 - Preserve evidence
 - Establish a chain of custody
 - Present findings

Forensics Techniques and Procedures (cont.)

- NIST Documents
 - Special Publication 800-72, Guidelines on PDA Forensics
 - Special Publication 800-86, Guide to Integrating Forensic Techniques into Incident Response
 - Special Publication 800-101, Guidelines on Cell Phone Forensics
 - Bulletin 11-01, Computer Forensics Guidance

Identifying and Gathering Evidence

- Size of storage a big challenge (lots of data to examine)
- Starting points in an investigation
 - E-mail
 - Web access
 - Stored data
 - Inappropriate access
- Look for leads, follow the trail

Evidence Collection Techniques

- Examination of surroundings
- Live system forensics
- Static system forensics
- Physical examination
- Examination of storage

Preserving Evidence

- Collection
- Recordkeeping
- Use of reliable tools
- Evidence safekeeping
- Work in isolation
- Chain of custody

Presentation of Findings

- Formal report
 - Explains the reason for the investigation
 - Shows the chain of evidence
 - Details on data that is found, and what it means
 - Contains only the facts, no speculation or anything about motives

Codes of Conduct

- Formal corporate statements that define acceptable behavior
 - Obey all laws
 - Always dress and act professionally
 - Avoid conflicts of interest
 - Avoid outside employment
 - Engage in good public relations through community activities
 - Avoid activities with customers or suppliers that would raise suspicion of favoritism or activities that result in personal gain
 - Use organizational resources and funds for business purposes only
 - Always maintain accuracy in all books, records and communications
 - Separate personal activities from business activities
 - Maintain privacy and confidentiality of all business related information

RFC 1087: Ethics and the Internet

- Unethical and unacceptable activities which purposely:
 - seeks to gain unauthorized access to the resources of the Internet,
 - disrupts the intended use of the Internet,
 - wastes resources (people, capacity, computer) through such actions,
 - destroys the integrity of computer-based information,
 - compromises the privacy of users.

Guidance on Ethical Behavior

- Behave transparently
- Make decisions openly
- Shun politics
- Show no favoritism or self-interest
- Respect the privacy and dignity of others
- Keep your commitments
- Promote accountability and responsibility
- Document your actions

Summary

- Computers have three roles in crimes: target, instrument, and support.
- The categories of computer crimes are political espionage and cyberwarfare, terrorism, theft and fraud, commercial espionage, harassment, hacktivism, and cybervandalism.
- The categories of U.S. laws are criminal, civil, and administrative.
- U.S. laws that protect information and computers are intellectual property laws, privacy laws, and computer crime laws.
- The types of intellectual property protections are copyrights, trademarks, and patents.

Summary (cont.)

- Security incident response consists of several steps including incident declaration, triage, investigation, analysis, containment, recovery, and debriefing.
- The primary activities in a forensic investigation are: identify and gather evidence, preserve evidence, establish a chain of custody, and present findings.
- Many organizations will develop a *code of conduct* to define the activities that are acceptable and unacceptable.
- The (ISC)² code of ethics defines the desired and undesired behavior that it expects of its CISSP and SSCP certification holders.

Summary (cont.)

- The Internet Activities Board (IAB) published *RFC 1087: Ethics and the Internet*, a statement of ethics concerning the acceptable use of the Internet.
- Security professionals should always conduct themselves so as not to ever give even the appearance of violating an organization's security policy or the (ISC)² Code of Ethics.